AIF-C01 · 內容領域 5

AI 解決方案的安全性、合規與管控

14%

考試計分占比

5.1 保障 AI 系統安全的方法

5.2 AI 系統的管控與合規法規

依 AWS 官方考試指南（AIF-C01）重新整理

領域 5 總覽：任務陳述

5.1

說明保障 AI 系統安全的方法

AWS 安全服務與功能 · 來源引用與資料血緣 · 資料工程安全 · AI 安全與隱私考量 · 幻覺偵測與接地技術

5.2

辨識 AI 系統的管控與合規法規

合規服務（Config、Inspector、Audit Manager、Artifact、CloudTrail、Trusted Advisor）· 資料控管策略 · 管控協定與安全範圍矩陣

AWS 共同責任模型

AWS 負責：雲端「的」安全

- 實體資料中心與硬體
- 網路與虛擬化基礎設施
- 受管服務本身的運行（如 Bedrock、SageMaker AI）

客戶負責：雲端「中」的安全

- 資料加密與金鑰管理
- IAM 權限與角色設定
- 網路配置（VPC、安全群組、PrivateLink）
- 提示詞、輸出與應用程式安全

保障 AI 系統安全的 AWS 服務與功能

IAM 角色、策略與權限

最小權限；以 SageMaker 執行角色存取 S3，不寫死金鑰

加密（AWS KMS）

靜態與傳輸中加密；客戶管理金鑰可審計使用紀錄

Amazon Macie

自動在 S3 中發現與分類 PII 等敏感資料

AWS PrivateLink

以 VPC 端點私有存取 Bedrock、SageMaker，流量不經公網

AgentCore Identity 與 Policy

Identity 管理代理身分與憑證；Policy 限制代理可呼叫的工具與動作（詳見下兩頁）

Amazon Bedrock 防護機制

內容過濾、PII 遮罩、提示攻擊防護、接地檢查

代理式 AI 的四層控管：各管什麼

AWS IAM	AWS 資源層	誰（使用者、角色）可以存取哪些 AWS 資源與 API 例：SageMaker 執行角色只能讀特定 S3 桶
AgentCore Identity	代理身分層	代理是誰、誰能呼叫它、它代表誰、用什麼憑證存取外部服務 例：代理代表使用者以 OAuth 讀取其行事曆
AgentCore Policy	工具授權層	代理可以呼叫哪些工具、在什麼條件下（確定性規則） 例：退款金額超過上限必須先人工核准
Bedrock 防護機制	內容安全層	模型的輸入與輸出內容是否安全：有害內容、PII、提示攻擊、接地 例：遮罩回應中的信用卡號

IAM 四大組件



使用者 Users

個人或服務的永久身份憑證。例：資料科學家帳號。最佳實踐：啟用 MFA、定期輪換、最小權限



群組 Groups

使用者集合，批量管理權限。例：ML-Team、Data-Scientists。按職能分組



角色 Roles

可承擔的臨時身份、無永久憑證。例：SageMaker 執行角色。優先使用角色而非使用者



政策 Policies

JSON 格式權限文件。例：S3 存取、SageMaker 操作。以受管政策為基礎、自訂細化

IAM 政策類型與重點原則

政策類型	用途	SageMaker 範例
受管政策	AWS 預先定義	AmazonSageMakerFullAccess（快速開始但權限較廣）
自訂政策	精確控制（最佳實踐）	只授予必要 S3 桶、限制特定操作
信任政策	定義誰可承擔角色	允許 SageMaker 服務承擔角色、跨帳戶存取
服務控制政策 SCP	組織層級權限邊界	限制可用區域、強制加密、禁止刪除

IAM 五大重點

- 最小權限原則
- 優先使用角色，避免永久憑證
- 啟用 MFA
- 以 IAM Access Analyzer 定期審查
- 用政策條件（IP、時間）限制存取

Amazon Bedrock AgentCore Identity：代理是誰、代表誰

為 AI 代理管理身分、驗證與憑證，讓代理能安全地代表使用者存取 AWS 資源與第三方服務



代理身分 Agent identity

每個代理都有自己的工作負載身分，不必共用使用者或開發者的長期憑證

入站驗證

驗證「誰可以呼叫這個代理」：以 JWT 整合既有身分提供者，如 Amazon Cognito、Okta、Microsoft Entra ID

出站驗證

代理「代表使用者」存取 AWS 或第三方服務（如 Slack、GitHub），透過 OAuth 或 API 金鑰的憑證提供者

安全保管憑證

權杖與金鑰集中保存於受保護的權杖保管庫，不寫死在程式碼或提示詞中

使用者同意

代表使用者存取第三方資料前，先取得使用者授權

整合與稽核

與 AgentCore Runtime、Gateway 原生整合；存取行為留有稽核紀錄

AgentCore Policy：用確定性規則限制代理能做什麼

在代理程式碼「之外」設下邊界：即使代理誤解規則或被提示注入操控，也無法越權呼叫工具

代理 › AgentCore Gateway › Policy 引擎評估 › 允許 → 呼叫工具
拒絕 → 阻擋並記錄

撰寫方式

以開源授權語言 Cedar 撰寫，或用自然語言描述再自動轉成 Cedar，並以自動推理檢查規則是否過寬或過嚴

三類條件

輸入型（誰、哪個工具、什麼參數）、工作階段型（需先核准、次數或預算上限）、提供者型（如防護機制分數過高就阻擋）

確定性執行

同樣的請求與政策一定得到同樣結果，不依賴 LLM 判斷，也與代理框架無關

稽核

每個允許 / 拒絕決策都記錄到 Amazon CloudWatch，便於合規審查

資料加密：靜態、傳輸中與金鑰管理

靜態加密

Encryption at Rest：儲存時加密

SSE-S3	S3 管理金鑰
SSE-KMS	推薦
SSE-C	客戶提供金鑰
客戶端加密	

ML 應用：訓練資料、模型工件、Feature Store、筆記本 EBS 卷

傳輸中加密

Encryption in Transit：傳輸時加密

TLS/SSL	HTTPS
VPC 端點	
容器間加密	
PrivateLink	

ML 應用：API 調用、分散式訓練通訊、推論請求、資料上傳下載

金鑰管理 KMS

AWS KMS：集中管理加密金鑰

AWS 管理金鑰	免費
客戶管理金鑰 CMK	推薦
CloudHSM	高合規需求

ML 應用：S3 加密、SageMaker 資源加密、CloudTrail 審計金鑰使用、自動輪換

資料治理：血緣、保留與存取控制



資料血緣 Data Lineage

記錄來源、追蹤轉換、標記使用位置、關聯模型版本

AWS 工具

SageMaker Lineage Tracking、Lake Formation、Pipelines、Glue DataBrew



資料保留與刪除

定義保留政策、自動歸檔、合規性刪除、成本優化

AWS 工具

S3 生命週期政策、S3 Glacier、標記自動化、資料刪除 API



資料存取控制

RBAC（角色基礎）、ABAC（屬性基礎）、最小權限、定期審查

AWS 工具

IAM 政策、S3 桶政策、Lake Formation 權限、SageMaker 資源政策

保障資料工程安全的最佳實務



評估資料品質

檢查完整性、正確性與一致性，避免垃圾進垃圾出



實作隱私增強技術

資料匿名化、遮罩、差分隱私、聯邦學習



資料存取控制

RBAC / ABAC、最小權限、Lake Formation 細粒度權限



資料完整性

版本控制、雜湊驗證、防止訓練資料被竄改（資料投毒）

AI 系統的安全與隱私考量

應用程式安全

API 驗證、輸入驗證、安全開發

威脅偵測

Amazon GuardDuty 等偵測異常行為

漏洞管理

Amazon Inspector 掃描漏洞

基礎設施保護

VPC、安全群組、WAF

提示注入

惡意指令覆蓋系統提示；以防護機制過濾

靜態與傳輸中加密

KMS、TLS

資料外洩防護

Macie、輸出過濾、最小權限

輸出過濾與驗證

檢查輸出是否含 PII 或有害內容

稽核追蹤與日誌

CloudTrail 記錄 AI 互動與 API 呼叫

毒性 Toxicity

過濾仇恨、暴力等有害內容

幻覺偵測與接地技術

RAG 接地 Grounding

讓模型根據檢索到的文件回答，並附上來源

輸出驗證

以規則、第二個模型或防護機制的情境接地檢查驗證輸出

信心評分

低信心的回答觸發人工審核（Amazon A2I）或拒答

情境接地檢查

Bedrock 防護機制檢查回應是否有來源依據、是否切題

自動推理檢查

以邏輯規則驗證回應是否符合政策

降低 Temperature

減少隨機性，讓輸出更保守

提示詞指示

「若不確定請回答不知道」

協助管控與法規遵循的 AWS 服務



AWS Config

追蹤資源配置變更，以規則評估是否合規



Amazon Inspector

自動掃描 EC2、容器映像與 Lambda 的軟體漏洞



AWS Audit Manager

持續蒐集證據、對照合規框架產生稽核報告（含生成式 AI 框架）



AWS Artifact

下載 AWS 的合規報告（如 SOC、ISO）與協議



AWS CloudTrail

記錄 API 呼叫：誰、何時、做了什麼——用於稽核



AWS Trusted Advisor

依最佳實務檢查成本、效能、安全、容錯並提出建議

CloudTrail、CloudWatch、Config 怎麼分

AWS CloudTrail

稽核

誰在何時呼叫了哪個 API、從哪裡、成功與否

Amazon CloudWatch

監控

指標、日誌、告警：系統運行得好不好

AWS Config

合規

資源配置是什麼、何時被改、是否符合規則

例：「找出是誰刪除了 SageMaker 端點」→ CloudTrail；「端點延遲升高要告警」→ CloudWatch；「檢查所有 S3 桶都有加密」→ Config

資料控管策略

資料生命週期

從建立、使用、歸檔到刪除的完整管理（S3 生命週期政策）

日誌記錄

記錄資料存取與 AI 互動（CloudTrail、模型調用日誌）

資料駐留 Residency

資料必須存放在特定國家或區域，影響模型與區域選擇

監控

持續監控資料品質與模型漂移（Model Monitor、CloudWatch）

觀察 Observability

追蹤整個 AI 應用與代理的執行路徑（如 AgentCore Observability）

保留 Retention

依法規設定保留期限，到期自動刪除

遵循管控協定的程序

政策	制定 AI 使用政策：允許的用途、資料分類、核准流程
審查頻率	定期檢視模型、權限與合規狀態（如每季）
審查策略	技術、法務、業務多方共同審查；風險越高審查越嚴
管控架構	以生成式 AI 安全範圍矩陣判斷責任與控制（下一頁）
透明度標準	揭露 AI 使用、模型限制與資料來源
團隊培訓要求	讓員工了解 AI 風險、政策與正確使用方式

日誌和監控工具



Amazon CloudWatch

即時監控與日誌：訓練指標（損失、準確率）、端點延遲與調用次數、CPU / 記憶體、錯誤率告警



AWS CloudTrail

API 呼叫審計追蹤：模型部署追蹤、資料存取審計、安全調查、合規要求



AWS Config

資源配置追蹤與合規檢查：配置變更歷史、合規規則評估、資源關係圖、配置快照



SageMaker Model Monitor

模型品質與偏差監控：資料漂移、模型品質、特徵歸因偏差、違規告警

生成式 AI 安全範圍矩陣

範圍 1

消費者應用

使用公開的第三方 GenAI 服務

例：員工用公開聊天工具發想點子

範圍 2

企業應用

使用內嵌 GenAI 的第三方企業軟體

例：排程軟體自動產生會議議程

範圍 3

預訓練模型

以現成 FM 透過 API 建置自己的應用

例：以 Bedrock 加 RAG 做客服機器人

範圍 4

微調模型

以自有資料微調現成 FM

例：以醫療術語微調模型摘要病歷

範圍 5

自訓模型

以自有資料從頭訓練模型

例：自行訓練影片插幀模型

範圍越往右，客戶擁有的模型與資料越多、責任越大；涵蓋治理與合規、法律與隱私、風險管理、控制措施、韌性五大面向

主要合規框架

框架	適用範圍	AI 實施重點
GDPR	歐盟居民個人資料	資料最小化、被遺忘權、自動化決策的解釋權
HIPAA	美國醫療健康資料	簽署 BAA、使用合格服務、全面加密與稽核
SOC 2	雲端服務提供商	AWS 已取得認證；報告可在 AWS Artifact 下載
PCI DSS	信用卡資料	訓練資料避免含卡號；標記化與遮罩
ISO 27001 / ISO 42001	資訊安全 / AI 管理系統	風險評估、政策、持續改進；ISO 42001 專為 AI 治理
EU AI Act	在歐盟提供的 AI 系統	依風險分級管理，高風險系統需更多透明與監督

情境練習

依官方考試目標整理，先遮住右欄自己作答

1. 在 S3 中自動找出含個資的訓練資料

2. 私有存取 Bedrock，流量不經公網

3. 限制 AI 代理只能呼叫特定工具

4. 使用者以指令覆蓋系統提示

5. 掃描推論容器映像的漏洞

6. 蒐集證據並產生稽核報告

7. 下載 AWS 的 SOC 報告

8. 查出是誰呼叫了刪除 API

9. 資料必須留在特定國家

10. 以 Bedrock 加 RAG 建客服機器人屬於哪個範圍

情境練習

依官方考試目標整理，先遮住右欄自己作答

1. 在 S3 中自動找出含個資的訓練資料	Amazon Macie
2. 私有存取 Bedrock，流量不經公網	AWS PrivateLink
3. 限制 AI 代理只能呼叫特定工具	AgentCore Policy
4. 使用者以指令覆蓋系統提示	提示注入
5. 掃描推論容器映像的漏洞	Amazon Inspector
6. 蒐集證據並產生稽核報告	AWS Audit Manager
7. 下載 AWS 的 SOC 報告	AWS Artifact
8. 查出是誰呼叫了刪除 API	AWS CloudTrail
9. 資料必須留在特定國家	資料駐留
10. 以 Bedrock 加 RAG 建客服機器人屬於哪個範圍	範圍 3：預訓練模型

自我檢核：領域 5 官方目標

☑	5.1	**保障 AI 安全的 AWS 服務**	IAM、加密、Macie、PrivateLink、共同責任、AgentCore Identity 與 Policy、防護機制
☑	5.1	**來源引用與文件化**	資料血緣、資料編目、SageMaker Model Cards
☑	5.1	**資料工程安全**	資料品質、隱私增強技術、存取控制、資料完整性
☑	5.1	**AI 安全與隱私考量**	應用安全、威脅偵測、漏洞、提示注入、加密、外洩防護、輸出過濾、稽核、毒性
☑	5.1	**幻覺偵測與接地**	RAG 接地、輸出驗證、信心評分
☑	5.2	**管控與合規服務**	Config、Inspector、Audit Manager、Artifact、CloudTrail、Trusted Advisor
☑	5.2	**資料控管策略**	生命週期、日誌、駐留、監控、觀察、保留
☑	5.2	**管控協定**	政策、審查頻率與策略、安全範圍矩陣、透明度標準、團隊培訓